JS

Jahangir Shukurov | GRC Portfolio

PROJECT 1 | ASSESSMENT REPORT

ISO/IEC 27001:2022 Gap Assessment

Findings, priorities and a 12-month roadmap to certification

Client	**Orvanta Payments UAB**
Document ID	**ORV-GAP-001**
Version	**1.0**
Date	**27 November 2026**
Classification	**Confidential (sample)**

> Sample engagement — fictional company, prepared for portfolio purposes.

Document control

Field	Value
Document ID	ORV-GAP-001
Title	ISO/IEC 27001:2022 Gap Assessment
Version	1.0
Date	27 November 2026
Author	Jahangir Shukurov
Reviewer	Nino Beridze, CISO-designate
Approver	Ugnė Baltrūnaitė, CEO
Classification	Confidential (sample)

Version history

Version	Date	Author	Change
0.1	23 November 2026	Jahangir Shukurov	Draft for CISO-designate review
1.0	27 November 2026	Jahangir Shukurov	Issued to the CEO and Management Board

Contents

1 Executive summary....3

2 Scope and method....4

2.1 Maturity scale....4

2.2 How priorities are set....4

3 Results....5

3.1 Maturity by clause....5

3.2 Climate change consideration....6

3.3 Maturity by Annex A theme....6

3.4 What already works....6

3.5 How this compares with the intake view....7

4 How an attacker would use these gaps....7

5 Top 10 priority gaps....8

6 Quick wins....9

7 12-month roadmap....10

7.1 Why the sequence works....11

7.2 Main risks to the plan....11

7.3 Limits of this assessment....11

8 Appendix: all P1 items....12

1 Executive summary

Situation. Three enterprise merchants worth EUR 2.4M a year require ISO/IEC 27001:2022 certification, and the target date is 30 November 2027. We assessed Orvanta against all 30 requirements of clauses 4 to 10 and all 93 Annex A controls. The goal is achievable, but only if the program starts in December 2026.

1.4 / 5	16%	38	12 months
Average maturity	At target (20 of 123)	P1 gaps, first 90 days	To certificate decision

Key findings.

- **The management system is missing.** No clause area averages above 1.2. No scope, risk treatment, audit or management review exists, and an auditor needs all of them.
- **The technology is ahead of the governance.** Encryption, Multi-AZ and infrastructure as code are real strengths, and 8 of 34 technological controls already meet target.
- **The most likely attack path is identity.** Shared admin accounts, five tools without enforced MFA and 43 unmanaged laptops make a stolen credential the biggest concern.
- **Detection and recovery are unproven.** There is no SIEM and no exercised incident plan, and no full restore is on record.

Risk in business terms. Delay puts EUR 2.4M of annual revenue, about 11% of FY2025 net revenue, at risk. Separately, the same gaps leave payment continuity, customer funds records and regulatory reporting exposed under DORA.

Decisions needed.

#	Decision	Owner	By
1	Sponsor the ISMS program as a board-level priority	Ugnė Baltrūnaitė	30 Nov 2026
2	Fund the roadmap, including a third security hire and a SIEM	Ugnė Baltrūnaitė	15 Dec 2026
3	Move the CISO reporting line from the CTO to the CEO	Ugnė Baltrūnaitė	31 Dec 2026
4	Include the Baku subsidiary in the ISMS scope	Tural Mammadli	15 Jan 2027
5	Commission a QSA review of PCI DSS scope and validation level	Nino Beridze	31 Jan 2027

2 Scope and method

This assessment covers Orvanta Payments UAB and Orvanta Engineering LLC: all products, AWS production, Vilnius, Baku and remote work. Fieldwork ran from 9 to 20 November 2026.

Evidence basis. Interviews and document reviews are simulated for this portfolio sample. They comprise 13 interviews and 22 documents, listed in the workbook's Evidence sheet.

2.1 Maturity scale

Score	Label	What it means
0	Absent	Nothing exists, or the need is not recognized.
1	Initial	Happens ad hoc and depends on individuals. Little or no documentation.
2	Repeatable	Done routinely by some teams, but informal, incomplete or inconsistent.
3	Defined	Documented, approved and working across scope, with evidence. Target for certification.
4	Measured	Performance is measured and reported, and acted on.
5	Optimized	Continuously improved and automated where sensible.

The target is level 3 for every item. Certification tests whether a control is defined, working and evidenced; chasing level 5 everywhere would cost money without helping the audit.

2.2 How priorities are set

Each open gap receives a score from a transparent formula. Weights sit in the workbook, so leadership can challenge and change them.

Factor	Points	Why it counts
Gap size	2 per level below target	Larger gaps take longer and carry more exposure
Certification blocker	2 if yes	Some gaps would likely stop the audit outright
Attack relevance	High 3, Medium 2, Low 1, None 0	Reflects how directly an attacker could exploit the gap

A score of 9 or more is P1 (start in the first 90 days), 6 to 8 is P2 (complete by mid-2027), and lower scores are P3.

3 Results

3.1 Maturity by clause

All 30 clause requirements are below target. Performance evaluation is the weakest area, because the ISMS has never been measured, audited or reviewed.

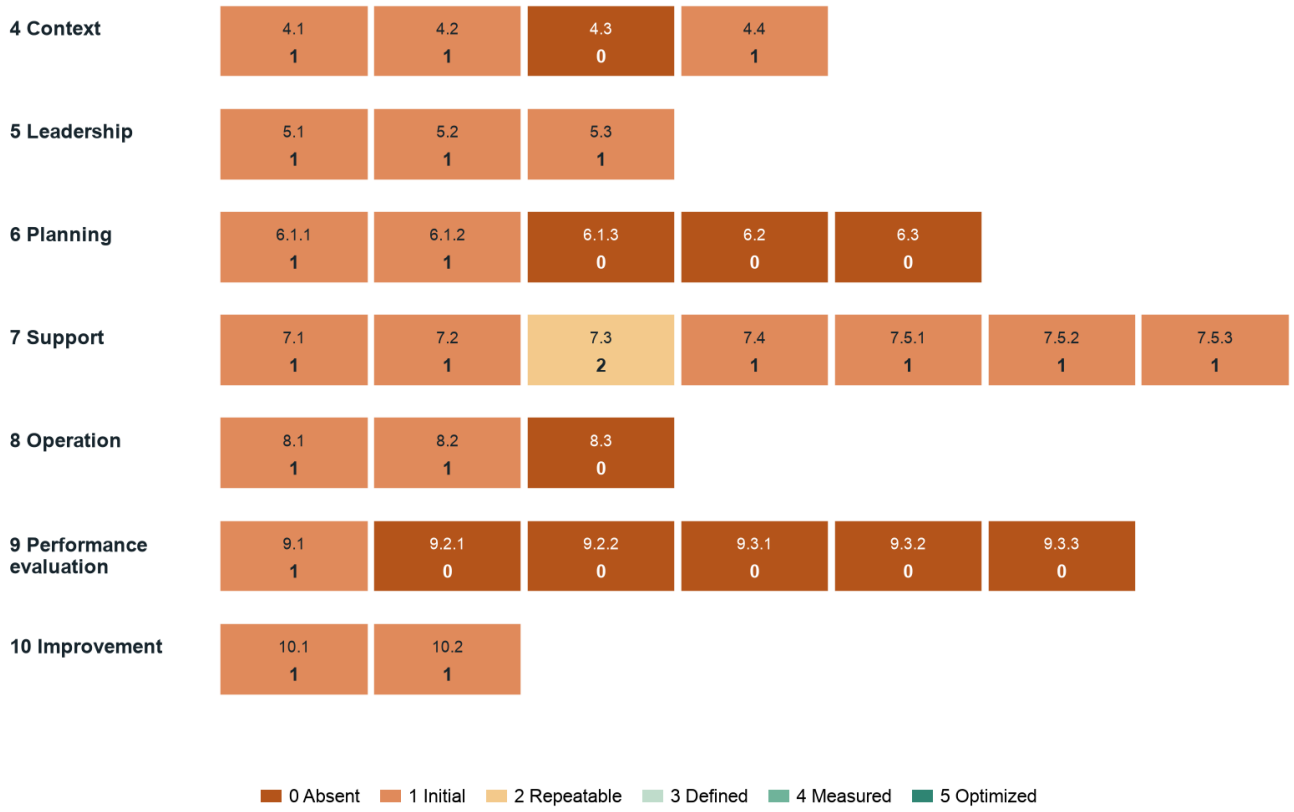


Figure 1: Maturity heat map for clauses 4 to 10. Each cell shows the requirement and its score.

The table summarizes clauses and Annex A themes together. Workbook formulas produce every figure.

Area	Items	Average	At target	P1	P2	P3
4 Context	4	0.8	0	1	3	0
5 Leadership	3	1.0	0	0	3	0
6 Planning	5	0.4	0	3	2	0
7 Support	7	1.1	0	0	7	0
8 Operation	3	0.7	0	1	2	0
9 Performance evaluation	6	0.2	0	3	3	0
10 Improvement	2	1.0	0	0	2	0
Organizational	37	1.1	2	15	12	8
People	8	2.1	3	1	1	3
Physical	14	2.3	7	1	1	5
Technological	34	1.7	8	13	7	6

3.2 Climate change consideration

Amendment 1:2024 asks organizations to decide whether climate change is a relevant issue, and notes that interested parties may have related requirements. Orvanta has not yet considered this. We expect limited direct relevance, but the decision must be recorded. Points to weigh include regional disruption affecting cloud or office services and sustainability questions from enterprise merchants.

3.3 Maturity by Annex A theme

Physical and people controls score best, because offices are simple and HR practice is sound. Organizational controls score lowest because they depend on governance that does not exist yet.

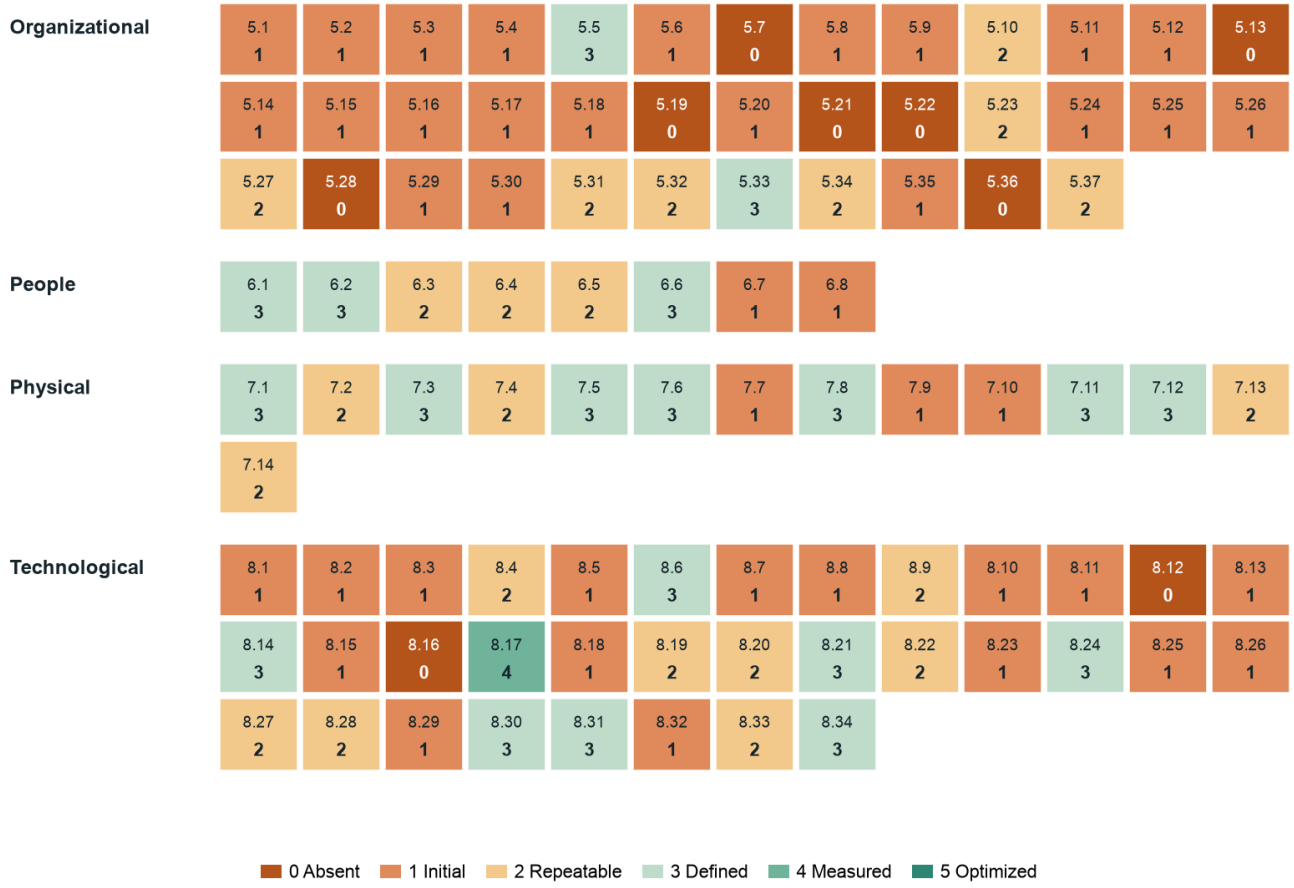


Figure 2: Maturity heat map for all 93 Annex A controls, by theme.

3.4 What already works

20 items already meet target. They matter for two reasons: the roadmap must not break them, and they show the engineering culture can run disciplined controls.

- **Resilient, encrypted platform.** Multi-AZ databases, KMS encryption at rest, TLS 1.2+ and synchronized clocks (A.8.14, A.8.24, A.8.17).
- **Separated environments.** Production, staging and development run in separate AWS accounts, defined in Terraform (A.8.31).
- **Sound hiring basics.** Screening, employment terms and NDAs are consistently applied (A.6.1, A.6.2, A.6.6).
- **Regulatory discipline.** Compliance keeps working contacts with the supervisor and retains ledger and AML records well (A.5.5, A.5.33).

3.5 How this compares with the intake view

The Company Fact Sheet recorded an indicative 1.6, based on 12 broad domains. This assessment finds 1.4. The lower score is expected: it adds the clause requirements, where almost nothing is formally in place, and it credits only what evidence supports.

4 How an attacker would use these gaps

A control gap matters most when it joins others into a path. The scenario below chains six gaps found in this assessment, from a phishing email to destroyed backups. Every step uses a weakness we observed, and none needs advanced skill.

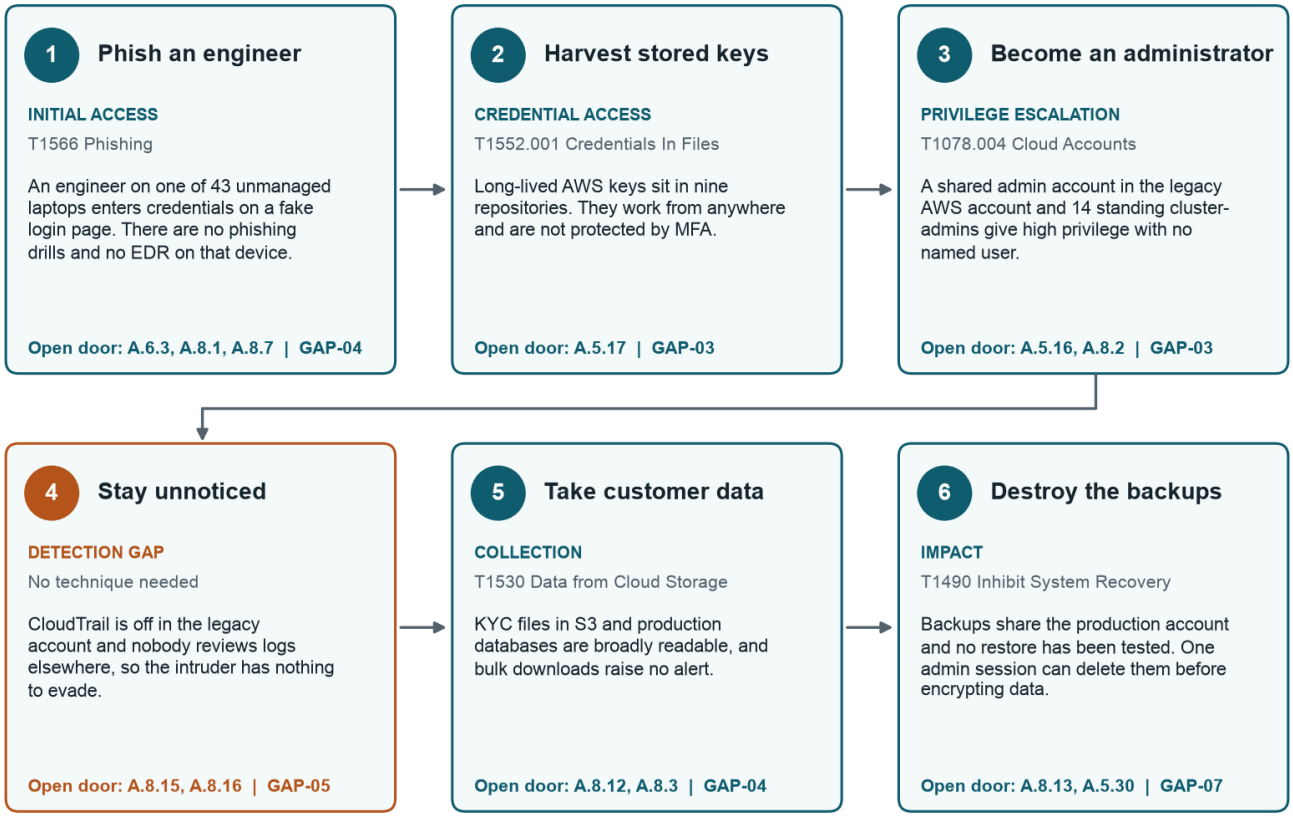


Figure 3: Illustrative attack path through current gaps. Technique IDs refer to MITRE ATT&CK.

> **Reading note.** This is a scenario, not evidence that an attack has happened. Project 2 develops it into full attack-scenario analysis with likelihood and impact.

Breaking the path at any step stops it. The table shows which planned actions close each door. Steps 3, 4 and 6 each have a quick win that starts closing them within 30 days.

Step	Attacker's move	Controls leaving the door open	Priority gap	Closed by
1	Phish an engineer	A.6.3, A.8.1, A.8.7	GAP-04	RM-08, RM-17
2	Harvest stored keys	A.5.17	GAP-03	RM-07
3	Become an administrator	A.5.16, A.8.2	GAP-03	QW-04, RM-07
4	Stay unnoticed	A.8.15, A.8.16	GAP-05	QW-01, RM-14
5	Take customer data	A.8.12, A.8.3	GAP-04	RM-12, RM-07
6	Destroy the backups	A.8.13, A.5.30	GAP-07	QW-07, RM-10

This is why identity, logging and backup actions sit early in the roadmap even where their paperwork gap looks small: they sit on the shortest route to customer data and the ledger.

5 Top 10 priority gaps

Rows in the workbook group into ten gaps, ranked by average priority score. Each is written for leadership: what could happen, and what fixes it. The average favors tightly focused gaps, so read it with the P1 count: GAP-03 and GAP-04 have the most P1 items.

1. Attacks would go undetected (GAP-05)

An intruder could stay for weeks. Longer dwell time means bigger losses, and late discovery undermines regulatory reporting.

Fix: Turn on full logging, deploy a SIEM and start daily triage with ATT&CK-mapped detections.

Owner: Nino Beridze | Target: Jun 2027 | 3 linked items, 3 P1 | Average maturity 0.3

2. No working risk management (GAP-02)

Security money goes wherever the last customer question pointed. Orvanta cannot show the Bank of Lithuania or an auditor why it chose its controls.

Fix: Adopt a method and complete a threat-informed risk assessment and treatment plan.

Owner: Lukas Jankauskas | Target: Mar 2027 | 5 linked items, 3 P1 | Average maturity 0.6

3. Suppliers are unassessed (GAP-08)

Critical services run through vendors nobody has assessed. A supplier breach could stop payments and is Orvanta's responsibility to regulators.

Fix: Tier all 20 vendors, assess Tier 1 and complete the DORA register of information.

Owner: Eglė Norvilaitė | Target: Jun 2027 | 5 linked items, 3 P1 | Average maturity 0.6

4. No assurance cycle (GAP-10)

Certification needs evidence that the ISMS is checked and improved. With no audit, review or corrective action, Stage 2 cannot pass.

Fix: Set KPIs, audit in July 2027, hold management review in August 2027 and close actions.

Owner: Eglė Norvilaitė | Target: Aug 2027 | 10 linked items, 4 P1 | Average maturity 0.4

5. Recovery is unproven (GAP-07)

If backups fail or are deleted, Orvanta may be unable to restore ledgers, risking customer funds records and its license standing.

Fix: Isolate backups, test restores every quarter, and complete a BIA with recovery objectives.

Owner: Rashad Guliyev | Target: May 2027 | 3 linked items, 2 P1 | Average maturity 1.0

6. Identity and privileged access are too open (GAP-03)

One stolen password could give an attacker control of production, customer data and the payment flow, with shared accounts hiding who acted.

Fix: Remove shared accounts, close five MFA gaps, cut standing admin rights and deprovision within 24 hours.

Owner: Rashad Guliyev | Target: Apr 2027 | 12 linked items, 7 P1 | Average maturity 1.2

7. Incident response is untested (GAP-06)

In a real attack, confused decisions could prolong outages and put regulatory notification duties at risk.

Fix: Approve a plan and two playbooks, then run a tabletop exercise.

Owner: Nino Beridze | Target: May 2027 | 6 linked items, 3 P1 | Average maturity 1.0

8. Sensitive data and endpoints are exposed (GAP-04)

Card numbers in tickets, 43 unmanaged laptops and undocumented Baku data access create breach, PCI DSS and GDPR exposure.

Fix: Purge card data, enroll all laptops, mask data and complete the transfer assessment.

Owner: Farid Ismayilov | Target: May 2027 | 16 linked items, 7 P1 | Average maturity 1.2

9. No ISMS foundation (GAP-01)

Without an approved scope, policy and objectives, no auditor can begin certification, so EUR 2.4M of enterprise revenue stays out of reach.

Fix: Approve scope, policy, roles and objectives in the first 90 days.

Owner: Nino Beridze | Target: Feb 2027 | 22 linked items, 2 P1 | Average maturity 1.0

10. Change control can be bypassed (GAP-09)

A compromised or rushed change can reach the payment platform unreviewed, causing outages or fraud. 14% of Q3 2026 deployments bypassed review.

Fix: Protect all production repositories, enforce the CI path and add security gates.

Owner: Tural Mammadli | Target: Apr 2027 | 12 linked items, 4 P1 | Average maturity 1.4

6 Quick wins

These eight actions need little budget and cut real risk within 30 days. They also build momentum and give the auditor early evidence.

ID	Action	Why it pays off	Owner	Days
QW-01	Enable CloudTrail in the legacy AWS account	Removes a blind spot in one configuration change	Rashad Guliyev	3
QW-02	Purge the 11 Zendesk tickets holding card numbers and turn on redaction	Reduces PCI DSS exposure and a searchable target	Mantas Žukas	7
QW-03	Enforce MFA on Kyrovia and on Helvora agent Zendesk logins	Closes two of five MFA gaps using existing features	Farid Ismayilov	14
QW-04	Cut Okta super admins from six to two, plus one break-glass account	Shrinks the highest-impact target quickly	Farid Ismayilov	7
QW-05	Turn on branch protection for all production repositories	Blocks the easiest route for unreviewed code	Tural Mammadli	14
QW-06	Set a 24-hour leaver rule, with Head of People notifying IT the same day	Cuts the nine-day median exposure right away	Justina Mockutė	14
QW-07	Run one full RDS restore into a clean account and record the result	Replaces assumption with evidence	Rashad Guliyev	21
QW-08	Create a one-page incident call list with a security report channel	Gives staff a way to raise the alarm today	Nino Beridze	7

7 12-month roadmap

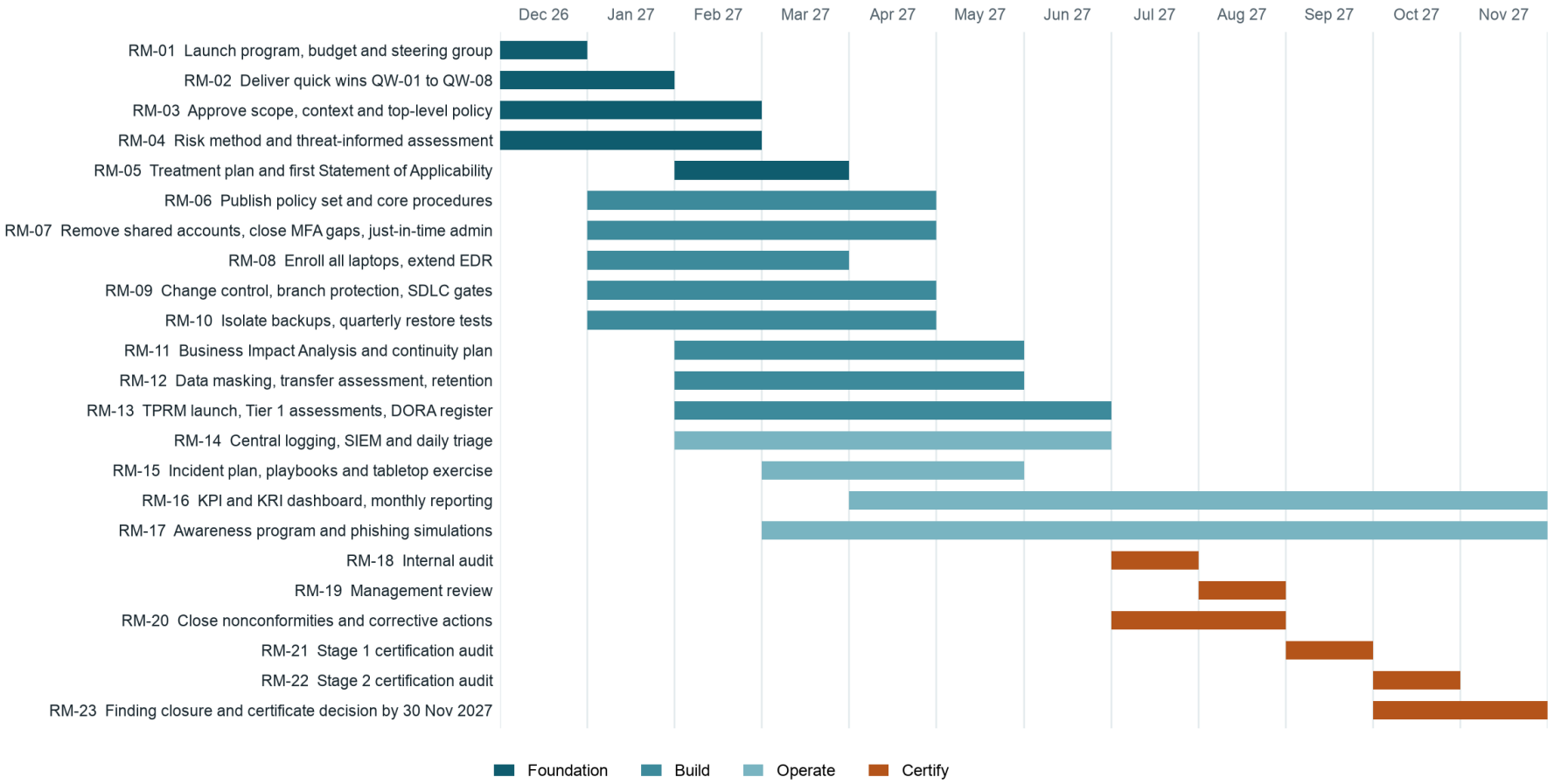


Figure 4: Roadmap from December 2026 to the certificate decision by 30 November 2027.

7.1 Why the sequence works

- **Foundation first.** Scope and risk results decide which controls apply, so they cannot wait.
- **Attack paths next.** Identity, endpoints, change control and backups are fixed early because they reduce real exposure now.
- **Records need time.** Controls must operate before auditors can sample them, so monitoring runs from April 2027.
- **Buffer before the deadline.** Stage 2 in October leaves time to close findings before 30 November 2027.

7.2 Main risks to the plan

Risk	Effect	Response
Security team stays at two people	SIEM and evidence work slip	Decide on the third hire by 15 December 2026
Feature pressure beats remediation	Roadmap items lose engineering time	Reserve capacity in each CTO team's plan
Certification body availability	Stage audit dates move	Book the auditor by March 2027
Vendors respond slowly	Tier 1 assessments run late	Start early and use existing assurance reports

7.3 Limits of this assessment

This is a point-in-time view based on interviews and sampled evidence, not a certification audit, and it does not guarantee a certification result. Applicability is settled in the Statement of Applicability, so some scored controls may change. Costs are outside its scope. Regulatory matters are not legal advice.

8 Appendix: all P1 items

The 38 requirements and controls rated P1, highest priority score first. The workbook holds evidence and recommendations for each.

ID	Requirement or control	Score	Priority	Effort	Owner	Gap
A.5.19	Information security in supplier relationships	0	11	M	Eglė Norvilaitė	GAP-08
A.8.16	Monitoring activities	0	11	L	Nino Beridze	GAP-05
4.3	ISMS scope	0	10	S	Ugnė Baltrūnaitė	GAP-01
6.1.3	Risk treatment and SoA	0	10	M	Lukas Jankauskas	GAP-02
8.3	Performing risk treatment	0	10	S	Lukas Jankauskas	GAP-02
A.5.22	Monitoring, review and change management of supplier services	0	10	M	Eglė Norvilaitė	GAP-08
6.1.2	Risk assessment process	1	9	M	Lukas Jankauskas	GAP-02
6.2	Objectives and planning	0	9	S	Nino Beridze	GAP-01
9.2.1	Internal audit: general	0	9	M	Eglė Norvilaitė	GAP-10
9.2.2	Internal audit programme	0	9	S	Eglė Norvilaitė	GAP-10
9.3.1	Management review: general	0	9	S	Ugnė Baltrūnaitė	GAP-10
A.5.3	Segregation of duties	1	9	M	Tural Mammadli	GAP-09
A.5.7	Threat intelligence	0	9	M	Nino Beridze	GAP-05
A.5.9	Inventory of information and other associated assets	1	9	M	Farid Ismayilov	GAP-04
A.5.15	Access control	1	9	M	Nino Beridze	GAP-03
A.5.16	Identity management	1	9	M	Farid Ismayilov	GAP-03
A.5.17	Authentication information	1	9	M	Rashad Guliyev	GAP-03
A.5.18	Access rights	1	9	M	Farid Ismayilov	GAP-03
A.5.21	Managing information security in the ICT supply chain	0	9	M	Nino Beridze	GAP-08
A.5.24	Information security incident management planning and preparation	1	9	M	Nino Beridze	GAP-06
A.5.25	Assessment and decision on information security events	1	9	S	Nino Beridze	GAP-06
A.5.26	Response to information security incidents	1	9	M	Nino Beridze	GAP-06
A.5.30	ICT readiness for business continuity	1	9	M	Rashad Guliyev	GAP-07
A.5.36	Compliance with policies, rules and standards for information security	0	9	M	Nino Beridze	GAP-10
A.6.7	Remote working	1	9	M	Nino Beridze	GAP-04
A.7.9	Security of assets off-premises	1	9	M	Farid Ismayilov	GAP-04
A.8.1	User endpoint devices	1	9	M	Farid Ismayilov	GAP-04
A.8.2	Privileged access rights	1	9	M	Rashad Guliyev	GAP-03
A.8.3	Information access restriction	1	9	M	Rashad Guliyev	GAP-03
A.8.5	Secure authentication	1	9	M	Farid Ismayilov	GAP-03
A.8.7	Protection against malware	1	9	M	Farid Ismayilov	GAP-04
A.8.8	Management of technical vulnerabilities	1	9	M	Rashad Guliyev	GAP-09
A.8.10	Information deletion	1	9	M	Karolis Vaitkus	GAP-04
A.8.12	Data leakage prevention	0	9	M	Nino Beridze	GAP-04
A.8.13	Information backup	1	9	M	Rashad Guliyev	GAP-07
A.8.15	Logging	1	9	S	Rashad Guliyev	GAP-05
A.8.25	Secure development life cycle	1	9	M	Tural Mammadli	GAP-09
A.8.32	Change management	1	9	M	Tural Mammadli	GAP-09